

ACTIVITÉ 3 – Classifier les attaques selon OWASP

Objectif pédagogique

Le stagiaire doit :

- Comprendre différents types d'attaques du cours
- Les relier à OWASP top 10
- Comprendre logique OWASP (catégories)
- Utiliser CWE comme aide simple

CONSIGNE GÉNÉRALE

Pour chaque attaque :

1. Donner une description simple
2. Identifier la catégorie OWASP
3. Choisir un CWE du tableau
4. Proposer une prévention simple

TABLEAU CWE (simplifié et adapté)

CWE	Quand l'utiliser
CWE-79	XSS
CWE-384	Session hijacking
CWE-284	Accès non autorisé
CWE-287	Authentification
CWE-319	HTTP en clair
CWE-16	Mauvaise configuration
CWE-798	Mot de passe par défaut
CWE-601	Redirection / phishing
CWE-400	DoS
CWE-20	Mauvaise validation des entrées

PARTIE 1 — Tableau principal (10 points)

Consigne

Compléter le tableau :

Attaque (du cours)	Description	OWASP	CWE	Prévention
--------------------	-------------	-------	-----	------------

XSS				
Session Hijacking				
Attaque HTTP (ex: Unicode)				
Default Password				
Phishing				
DDoS				

PARTIE 2 — Comprendre OWASP (5 points)

Associer chaque attaque à une catégorie OWASP :

Attaque	OWASP 2021/2025
XSS	
Session hijacking	
HTTP vulnérable	
Mauvaise configuration	
Phishing	
DDoS	

PARTIE 3 — Analyse simple (3 points)

Question

Pourquoi OWASP ne contient pas directement :

- Phishing
- DDoS

Alors que ce sont des attaques importantes ?

PARTIE 4 — Réflexion (2 points)

Quelle différence entre :

- Une **attaque OWASP**
- Une **attaque réseau (ex: DDoS)**